中国中车集团有限公司办公室

内部事项　　中车集团办科信〔2026〕18号

关于开展OpenClaw（“龙虾”）等开源智能体安全风险排查工作的通知

中国中车集团有限公司各一级子公司，中国中车股份有限公司各一级子公司，总部各部门：

国家网络安全监管部门监测发现，“龙虾”等开源智能体（及相关衍生组件）存在较高安全风险，该智能体若被引入内部系统，极易被攻击者利用进行横向移动、数据窃取或植入勒索病毒，对网络安全造成较大威胁隐患。为贯彻落实国家有关部门和集团党委工作要求，保障集团及各子企业信息系统网络和数据安全，切实做好开源智能体风险防范，决定组织开展专项排查工作。现将有关要求通知如下。

一、全面组织开展排查，梳理本企业使用开源智能体情况，摸清安全风险底数。

二、各企业要严格执行内部办公网络与互联网有效隔离，禁止计算机等办公设备内、外网混用。尤其是境外企业、境外人员严禁办公电脑、办公移动设备未经集团批准安装各类智能体，严控各类风险。

三、对于网络安全防护等级三级及以上网络系统，或存储重要数据、核心数据的网络系统，未经本企业充分论证和安全测试，未经集团批准，不得部署安装各类开源智能体。

四、对于其他网络系统，建议谨慎使用，并参照《关于防范OpenClaw（“龙虾”）开源智能体安全风险的“六要六不要”建议》（附件1）等规范，做好针对性风险防范。

五、加强网络和数据安全监测，一旦发现或获知开源智能体引发的本企业安全事件，第一时间处置，并向集团报告。

各企业要认真落实通知要求，于2026年4月10日前将开源智能体安全风险排查情况（附件2）通过内网办公邮箱报集团科信部（电子邮箱：010099900594@crrcgc.cc）。

联系人及联系电话：集团科信部齐希同，17707336697；

信息公司张振威，18600540011。

附件：1.关于防范OpenClaw（“龙虾”）开源智能体安全风险的“六要六不要”建议

2.“龙虾”等开源智能体安全风险排查反馈表

中国中车集团有限公司办公室

2026年3月25日

抄送：公司领导，总师级领导，纪委副书记、工会副主席。

附 件

关于防范 OpenClaw（“龙虾”）开源智能体安全风险的“六要六不要”建议

针对“龙虾”典型应用场景下的安全风险，工业和信息化部网络安全威胁和漏洞信息共享平台（NVDB）组织智能体提供商、漏洞收集平台运营单位、网络安全企业等，研究提出“六要六不要”建议。

一、典型应用场景安全风险

（一）智能办公场景主要存在供应链攻击和企业内网渗透的突出风险

1. 场景描述：通过在企业内部部署“龙虾”，对接企业已有管理系统，实现智能化数据分析、文档处理、行政管理、财务辅助和知识管理等。

2. 安全风险：引入异常插件、“技能包”等引发供应链攻击；网络安全风险在内网横向扩散，引发已对接的系统平台、数据库等敏感信息泄露或丢失；缺乏审计和追溯机制情况下易引发合规风险。

3. 应对策略：独立网段部署，与关键生产环境隔离运行，禁止在内部网络使用未审批的“龙虾”智能体终端；部署前进行充分安全测试，部署时采取最小化权限授予，禁止非必要的跨网段、跨设备、跨系统访问；留存完整操作和运

行日志，确保满足审计等合规要求。

（二）开发运维场景主要存在系统设备敏感信息泄露和被劫持控制的突出风险

1. 场景描述：通过企业或个人部署“龙虾”，将自然语言转化为可执行指令，辅助进行代码编写、代码运行、设备巡检、配置备份、系统监控、管理进程等。

2. 安全风险：非授权执行系统命令，设备遭网络攻击劫持；系统账号和端口信息暴露，遭受外部攻击或口令爆破；网络拓扑、账户口令、API 接口等敏感信息泄露。

3. 应对策略：避免生产环境直接部署使用，优先在虚拟机或沙箱中运行；部署前进行充分安全测试，部署时采取最小化权限授予，禁止授予管理员权限；建立高危命令黑名单，重要操作启用人工审批机制。

（三）个人助手场景主要存在个人信息被窃和敏感信息泄露的突出风险

1. 场景描述：通过个人即时通讯软件等远程接入本地化部署的“龙虾”，提供个人信息管理、日常事务处理、数字资产整理等，并可作为知识学习和生活娱乐助手。

2. 安全风险：权限过高导致恶意读写、删除任意文件；互联网接入情况下遭受网络攻击入侵；通过提示词注入误执行危险命令，甚至接管智能体；明文存储密钥等导致个人信息泄露或被窃取。

3. 应对策略：加强权限管理，仅允许访问必要目录，

禁止访问敏感目录；优先通过加密通道接入，禁止非必要互联网访问，禁止高危操作指令或增加二次确认；严格通过加密方式存储 API 密钥、配置文件、个人重要信息等。

（四）金融交易场景主要存在引发错误交易甚至账户被接管的突出风险

1. 场景描述：通过企业或个人部署“龙虾”，调用金融相关应用接口，进行自动化交易与风险控制，提高量化交易、智能投研及资产组合管理效率，实现市场数据抓取、策略分析、交易指令执行等功能。

2. 安全风险：记忆投毒导致错误交易，身份认证绕过导致账户被非法接管；引入包含恶意代码的插件导致交易凭证被窃取；极端情况下因缺乏熔断或应急机制，导致智能体失控频繁下单等风险。

3. 应对策略：实施网络隔离与最小权限，关闭非必要互联网端口；建立人工复核和熔断应急机制，关键操作增加二次确认；强化供应链审核，使用官方组件并定期修复漏洞；落实全链路审计与安全监测，及时发现并处置安全风险。

二、安全使用建议

（一）使用官方最新版本。要从官方渠道下载最新稳定版本，并开启自动更新提醒；在升级前备份数据，升级后重启服务并验证补丁是否生效。**不要**使用第三方镜像版本或历史版本。

（二）严格控制互联网暴露面。要定期自查是否存在互

联网暴露情况，一旦发现立即下线整改。**不要**将“龙虾”智能体实例暴露到互联网，确需互联网访问的可以使用 SSH 等加密通道，并限制访问源地址，使用强密码或证书、硬件密钥等认证方式。

（三）坚持最小权限原则。要根据业务需要授予完成任务必需的最小权限，对删除文件、发送数据、修改系统配置等重要操作进行二次确认或人工审批。优先考虑在容器或虚拟机中隔离运行，形成独立的权限区域。**不要**在部署时使用管理员权限账号。

（四）谨慎使用技能市场。要审慎下载 ClawHub “技能包”，并在安装前审查技能包代码。**不要**使用要求“下载 ZIP”、“执行 shell 脚本”或“输入密码”的技能包。

（五）防范社会工程学攻击和浏览器劫持。要使用浏览器沙箱、网页过滤器等扩展阻止可疑脚本，启用日志审计功能，遇到可疑行为立即断开网关并重置密码。**不要**浏览来历不明的网站、点击陌生的网页链接、读取不可信文档。

（六）建立长效防护机制。要定期检查并修补漏洞，及时关注 OpenClaw 官方安全公告、工业和信息化部网络安全威胁和漏洞信息共享平台等漏洞库的风险预警。党政机关、企事业单位和个人用户可以结合网络安全防护工具、主流杀毒软件进行实时防护，及时处置可能存在的安全风险。**不要**禁用详细日志审计功能。

附录：部分安全基线及配置参考

一、智能体部署

创建 OpenClaw 专有用户，切勿使用 sudo 组：

sudo adduser --shell /bin/rbash --disabled-password clawuser

通过创建的专有用户登录操作系统。

创建受限的命令目录，禁止 rm、mv、dd、format、powershell 等：

sudo mkdir -p /home/clawuser/bin

sudo ln -s /bin/ls /home/clawuser/bin/ls

sudo ln -s /bin/echo /home/clawuser/bin/echo

强制设置 PATH 并只读，如在 /etc/profile.d/restricted_clawuser.sh 修改配置：

echo 'if ["$USER" = "clawuser"]; then export PATH=/home/clawuser/bin; readonly PATH; fi' | sudo tee /etc/profile.d/restricted_clawuser.sh

sudo chmod 644 /etc/profile.d/restricted_clawuser.sh

禁用 root 登录：

sudo sed -i 's/^#\?PermitRootLogin.*/PermitRootLogin no/' /etc/ssh/sshd_config

sudo systemctl restart sshd

二、限制互联网访问

（一）Linux 服务器配置

创建自定义链:

sudo iptables -N ALLOWED_IPS

添加允许的 IP（IP 地址为示例，操作时需替换为实际 IP 地址）:

sudo iptables -A ALLOWED_IPS -s 192.168.1.100 -j ACCEPT

sudo iptables -A ALLOWED_IPS -s 10.0.0.5 -j ACCEPT

sudo iptables -A ALLOWED_IPS -s 172.24.57.160 -j ACCEPT

sudo iptables -A ALLOWED_IPS -j RETURN

应用到 SSH 端口:

sudo iptables -A INPUT -p tcp --dport 22 -j ALLOWED_IPS

sudo iptables -A INPUT -p tcp --dport 17477 -j ALLOWED_IPS

此外，可参考上述命令关闭以下端口互联网访问或设置 IP 地址白名单: Telnet（23）、Windows 文件共享（135、137、138、139、445）、Windows 远程桌面（3389）、远程桌面控制（5900-5910）、数据库类端口（3306、5432、6379、27017）。

（二）VPN 接入的情况下配置

将 OpenClaw Gateway 绑定 127.0.0.1，切勿直接绑定到 0.0.0.0。

关闭 18789 端口:

sudo ufw deny 18789

远程访问时强制使用 VPN 并启用 Gateway 认证（在 openclaw.json 中设置 gateway.auth.mode: "token"及强令牌）。

三、开启详细日志

开启日志记录:

openclaw gateway --log-level debug >> /var/log/openclaw.log 2>&1

四、文件系统访问控制

在 Docker 部署配置文件(docker-compose.yml)中，利用 volumes 参数将系统关键目录挂载为:ro（只读）模式，仅保留特定的/workspace 为可写状态。

在宿主机系统层，通过 chmod 700 指令对私密数据目录实施强制访问控制:

sudo chmod 700 /path/to/your/workspace

五、第三方技能审查

安装前执行技能审查命令:

openclaw skills info <skill>

并审查~/.openclaw/skills/<skill>/SKILL.md 文件，确认无恶意指令（如 curl、bash）。

优先选用内置 55 个 Skill 或社区精选列表（如 awesome-openclaw-skills）。

六、安全自检

定期运行安全审计命令:

openclaw security audit

针对审计发现的安全隐患，如网关认证暴露、浏览器控

制暴露等，及时按照上述安全基线及配置参考、官方手册等进行处置。

七、更新版本

运行版本更新命令:

openclaw update

八、卸载

打开终端，执行删除命令:

openclaw uninstall

使用鼠标上下移动光标，按空格键勾选所有选项，然后按回车键确认。

选择 yes 并按回车，此命令会自动删除 OpenClaw 的工作目录。

卸载 npm 包:

1. 使用 npm 安装 openclaw 对应卸载命令:

npm rm -g openclaw

2. 如果使用 pnpm 安装 openclaw 对应卸载命令:

pnpm remove -g openclaw

3. 如果使用 bun 安装 openclaw 对应卸载命令:

bun remove -g openclaw